SIMATS ENGINEERING
CSA6303- Threat Intelligence and Network Security
A1-Threat Intelligence Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.No	192412470	**Name**	C Amareswar Reddy
Faculty	Dr.V.Parthipan	**Slot**	A

Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

Code of Conduct:

*I **C Amareswar Reddy/192412470** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of Student C Amareswar Reddy

Questions

Q1. Malware [5 Marks]

Define malware and explain any four types of malware (virus, worm, trojan, ransomware, spyware). For each type, state how it spreads and one impact on the victim.

Q2. Phishing [5 Marks]

Describe how a phishing attack is carried out. Differentiate between spear phishing, whaling and vishing, and list three measures an organisation can adopt to reduce phishing risk.

Q3. DoS and DDoS [5 Marks]

Distinguish between a Denial of Service (DoS) attack and a Distributed Denial of Service (DDoS) attack. Explain the working of a SYN flood and outline two mitigation techniques.

Q4. Man-in-the-Middle Attacks [5 Marks]

What is a Man-in-the-Middle (MITM) attack? Explain two techniques used to carry it out (for example ARP poisoning, rogue Wi-Fi access point, SSL stripping) and state how encryption helps defend against it.

Q5. Spoofing and Sniffing [5 Marks]

Compare spoofing and sniffing. Explain IP spoofing and ARP spoofing with an example each, and describe how packet sniffers such as Wireshark can be used both maliciously and legitimately.

Q6. Vulnerability Assessment [5 Marks]

Explain the vulnerability assessment process. Describe its main phases, and differentiate between vulnerability assessment and penetration testing. Name two commonly used scanning tools.

Q7. Vulnerability Scoring [5 Marks]

What are CVE and CVSS? Explain how CVSS scores help in prioritising vulnerabilities and why a high CVSS score alone may not decide the order of patching.

Q8. Threat Data Sources and OSINT [5 Marks]

Discuss the main sources of threat data (internal, external, open-source and commercial). Define Open-Source Intelligence (OSINT) and describe three OSINT sources or tools used in threat intelligence gathering.

Q9. Indicators of Compromise (IoCs) [5 Marks]

What are Indicators of Compromise (IoCs)? Classify them into network-based, host-based and file-based indicators with two examples of each, and explain how a security team uses IoCs during incident response.

Q10. Threat Feeds [5 Marks]

Explain what a threat intelligence feed is. Describe the common feed formats and sharing standards (STIX/TAXII), list two advantages and two limitations of using threat feeds, and name two example feeds.

ASSINMENT ANSWERS:-

Q1. Malware

Definition: Malware is malicious software designed to damage systems, steal information, or gain unauthorised access.

Four Types of Malware:

1. **Virus:** Attaches itself to files and spreads when infected files are opened. It can corrupt or delete data.

2. **Worm:** Replicates and spreads automatically through networks. It consumes bandwidth and slows systems.

3. **Trojan Horse:** Disguises itself as legitimate software. It can steal sensitive information.

4. **Ransomware:** Encrypts files and demands money for recovery. It can cause data loss and financial damage.

Prevention: Use antivirus software, update systems regularly, and avoid suspicious downloads.

Q2. Phishing

Definition: Phishing is a cyberattack in which attackers trick users into revealing sensitive information through fake emails, messages, or websites.

Working of Phishing:

1. The attacker sends a fake email or message.
2. The victim clicks a malicious link.
3. A fake website asks for personal information.
4. The victim enters passwords or banking details.
5. The attacker steals and misuses the information.

Types:

- **Spear Phishing:** Targets a specific person or organisation.
- **Whaling:** Targets senior executives or important officials.
- **Vishing:** Uses fraudulent phone calls to steal information.

Three Prevention Measures:

1. Provide security awareness training.
2. Use multi-factor authentication (MFA).
3. Use email spam filters and anti-phishing software.

Q3. DoS and DDoS

Definition: A DoS attack makes a service unavailable by overwhelming it with requests. A DDoS attack uses multiple compromised devices to attack a target.

Differences:

DoS	**DDoS**
Usually uses one attacking system.	Uses multiple attacking systems.
Easier to identify the source.	More difficult to identify the sources.

Generally generates less traffic.	Can generate large volumes of traffic.

Working of SYN Flood:

1. The attacker sends many TCP SYN requests.
2. The server responds with SYN-ACK messages.
3. The attacker does not complete the TCP handshake.
4. Half-open connections consume server resources.
5. Legitimate users may be unable to connect.

Mitigation:

1. Use SYN cookies.
2. Use firewalls and DDoS protection services.

Q4. Man-in-the-Middle Attacks

Definition: A Man-in-the-Middle (MITM) attack occurs when an attacker secretly intercepts or modifies communication between two parties.

Two Techniques:

1. ARP Poisoning:

- The attacker sends fake ARP messages on a local network.
- This redirects network traffic through the attacker's device.
- Example: Intercepting traffic between a computer and its gateway.

2. Rogue Wi-Fi Access Point:

- The attacker creates a fake Wi-Fi hotspot.
- Users connect to it, believing it is legitimate.
- The attacker may monitor their network traffic.

Role of Encryption:

- HTTPS and TLS encrypt data during transmission.

- Digital certificates help verify website identity.
- Strong encryption prevents attackers from easily reading or modifying protected data.

Prevention: Use HTTPS, trusted Wi-Fi networks, and valid digital certificates.

Q5. Spoofing and Sniffing

Spoofing: Falsifying information to impersonate a trusted device or system.

Sniffing: Capturing and analysing network packets.

Differences:

Spoofing	Sniffing
Falsifies identity or information.	Captures network traffic.
Can redirect traffic.	Can expose unencrypted data.

IP Spoofing:

- The attacker creates packets with a forged source IP address.
- Example: Sending packets with a fake IP address to hide the actual source.

ARP Spoofing:

- The attacker sends fake ARP messages to associate their MAC address with another device's IP address.
- Example: Redirecting local network traffic through the attacker's computer.

Uses of Wireshark:

- **Malicious:** Capturing sensitive information without permission.
- **Legitimate:** Troubleshooting networks and investigating security incidents.

Q6. Vulnerability Assessment

Definition: Vulnerability assessment is the process of identifying, analysing, and prioritising security weaknesses in systems and networks.

Main Phases:

1. **Planning:** Define the scope and obtain permission.
2. **Information Gathering:** Collect system and network information.
3. **Scanning:** Identify vulnerabilities using scanning tools.
4. **Analysis:** Evaluate and prioritise vulnerabilities based on risk.
5. **Reporting and Remediation:** Document findings, apply fixes, and perform follow-up scans.

Difference Between Vulnerability Assessment and Penetration Testing:

Vulnerability Assessment	Penetration Testing
Identifies security weaknesses.	Tests whether weaknesses can be exploited.
Focuses on identifying and prioritising vulnerabilities.	Focuses on validating attack paths and impact.

Tools:

1. Nessus
2. OpenVAS

Q7. Vulnerability Scoring

CVE (Common Vulnerabilities and Exposures): A system that provides unique identifiers for publicly known cybersecurity vulnerabilities.

CVSS (Common Vulnerability Scoring System): A standard used to measure the severity of security vulnerabilities on a scale from 0.0 to 10.0.

CVSS Severity Levels:

Score	Severity
0.0	None
.1–3.9	Low

4.0–6.9	0Medium
7.0–8.9	High
9.0–10.0	Critical

Importance of CVSS:

1. Helps prioritise vulnerabilities.
2. Supports patching decisions.
3. Helps communicate security risks.

Why CVSS Alone Is Not Enough:

- Active exploitation must be considered.
- The importance of the affected system matters.
- Internet exposure and business impact affect priority.

Conclusion: CVSS measures technical severity, while patching priority should be based on overall risk.

Q8. Threat Data Sources and OSINT

Definition: Threat intelligence is information about cyber threats used to protect systems and networks.

Main Threat Data Sources:

1. **Internal:** Firewall logs, SIEM alerts, and incident reports.
2. **External:** Information from security researchers and industry partners.
3. **Open-Source:** Public security reports, websites, and vulnerability databases.
4. **Commercial:** Paid threat intelligence services and security reports.

OSINT: Open-Source Intelligence is the collection and analysis of information from publicly available sources.

Three OSINT Tools:

1. **VirusTotal:** Analyses suspicious files and URLs.

2. **Shodan:** Identifies internet-connected devices and exposed services.

3. **MITRE ATT&CK:** Provides information about attacker tactics and techniques.

Conclusion: Threat data and OSINT help organisations identify threats and improve security.

Q9. Indicators of Compromise (IoCs)

Definition: Indicators of Compromise (IoCs) are signs that indicate a system or network may have been attacked.

Types of IoCs:

1. Network-Based Indicators:

- Suspicious IP addresses.
- Malicious domain names.

2. Host-Based Indicators:

- Unusual running processes.
- Unauthorised system configuration changes.

3. File-Based Indicators:

- Malicious file hashes.
- Suspicious executable files.

Uses During Incident Response:

1. **Detection:** Identify suspicious activities.

2. **Investigation:** Find affected systems.

3. **Containment:** Isolate infected devices and block malicious connections.

4. **Eradication:** Remove malware and attacker access.

5. **Recovery:** Restore systems and monitor for further attacks.

Conclusion: IoCs help security teams detect, investigate, and respond to cyberattacks.

Q10. Threat Feeds

Definition: A threat intelligence feed is a regularly updated collection of information about malicious IP addresses, domains, file hashes, and other cyber threats.

Common Formats and Standards:

1. **CSV:** Stores threat information in rows and columns.
2. **JSON:** Stores structured information in a machine-readable format.
3. **STIX:** Standard language for representing and sharing cyber threat intelligence.
4. **TAXII:** Protocol used to exchange threat intelligence between systems.

Two Advantages:

1. Helps detect known threats quickly.
2. Supports automated security monitoring and blocking.

Two Limitations:

1. May contain outdated information or false positives.
2. May not detect new or unknown attacks.

Two Examples of Threat Feeds:

1. **AlienVault OTX:** Shares threat intelligence and IoCs.
2. **URLhaus:** Tracks URLs associated with malware distribution.

Conclusion: Threat feeds improve threat detection and information sharing when combined with other security controls.

Marking Scheme (for evaluator)

Q.No	Expected points and mark distribution (total 5)
1	Definition (1); four types with spread method and impact (4 x 1 = 4).
2	Attack flow (1.5); three variants differentiated (1.5); three countermeasures (2).

3	DoS vs DDoS (1.5); SYN flood working (1.5); two mitigations such as rate limiting, SYN cookies, CDN/scrubbing, blackhole routing (2).
4	Definition and interception concept (1); two techniques (2); defences such as TLS, HSTS, certificate validation, VPN (2).
5	Comparison (1); IP and ARP spoofing with examples (2); sniffer dual use (1.5); one countermeasure (0.5).
6	Phases: asset discovery, scanning, analysis and prioritisation, reporting, remediation (2); VA vs pen test (2); two tools such as Nessus, OpenVAS, Qualys (1).
7	CVE meaning (1); CVSS meaning and severity ratings (1.5); role in prioritisation (1.5); context factors such as exploitability and asset criticality (1).
8	Threat data source categories (2); OSINT definition (1); three OSINT sources or tools such as Shodan, VirusTotal, WHOIS, social media, dark web monitoring (2).
9	Definition (1); classification with examples (3); use in detection and response (1).
10	Definition (1); STIX/TAXII or similar formats (1.5); two advantages and two limitations
	(2); two example feeds such as AlienVault OTX, MISP, abuse.ch (0.5).